武汉大学 国家网络安全学院
SCHOOL OF CYBER SCIENCE AND ENGINEERING·WHU

信息系统安全

（Information System Security）

武汉大学
王鹃

jwang@whu.edu.cn

目录

- 信息系统安全概述
- 软件安全与恶意代码
- 渗透测试方法及工具
- 模糊测试与漏洞挖掘
- 用户身份认证机制
- 访问控制模型
- 操作系统基础安全机制
- 硬件安全与可信计算
- 系统风险评估方法与工具
- 信息系统安全研究新方向

第七章 操作系统基础安全机制

LISS
空天信息安全与可信计算
教育部重点实验室

操作系统基础安全机制

1、 Windows安全模型和访问控制机制

2、 Linux基本访问控制机制

3、 Selinux

LISS
空天信息安全与可信计算
教育部重点实验室

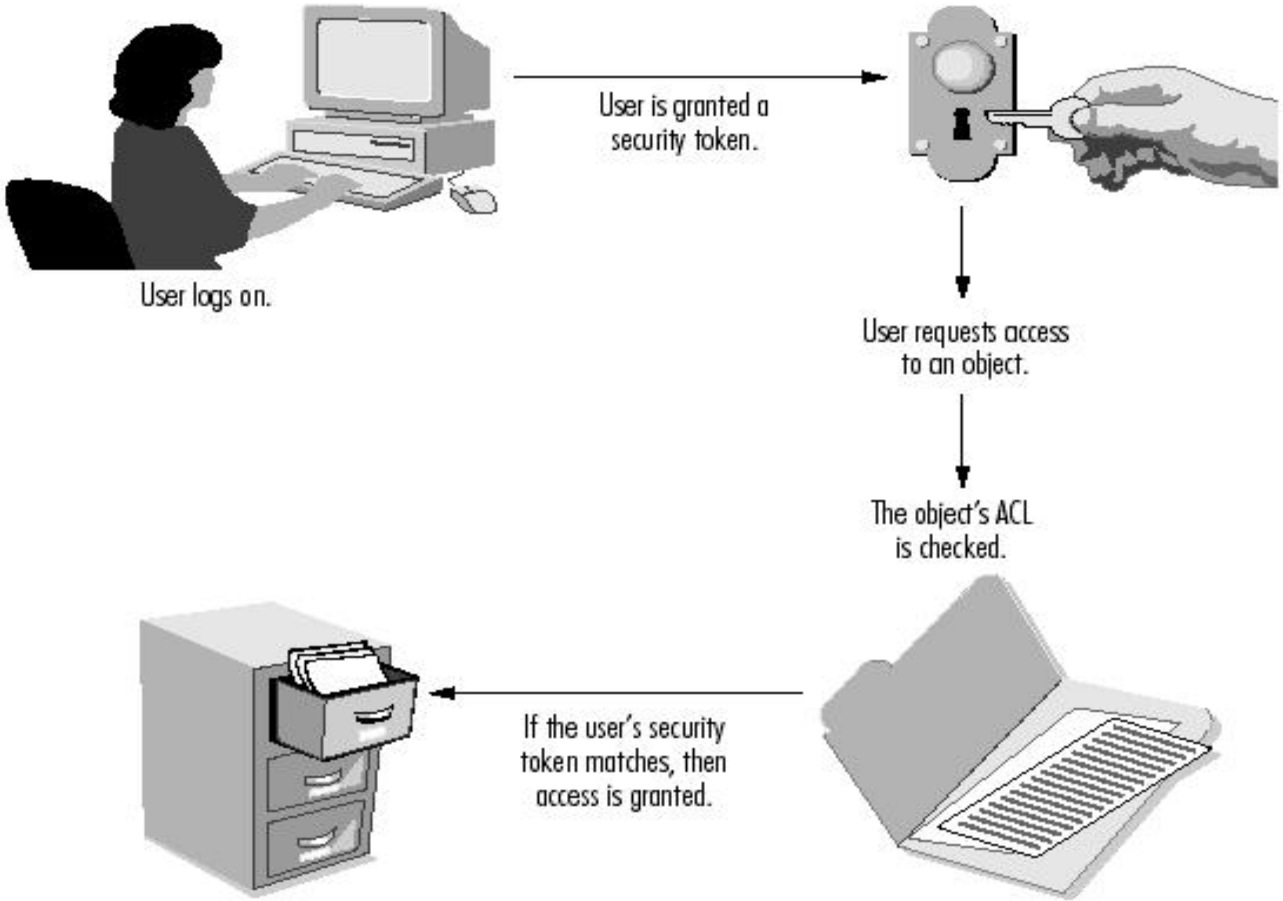
1、Windows安全模型

- Windows采用的是微内核 (microkernel) 结构和模块化的系统设计。有的模块运行在底层的内核模式上，有的模块则运行在受内核保护的用户模式上。
- Windows的安全子系统置于核心 (kernel) 层。
- 安全子系统的主要任务：身份认证和访问控制

LISS
空天信息安全与可信计算
教育部重点实验室

Windows安全模型

Figure 3: The Flow of Security Reference Monitoring



Windows的安全模型

- Windows安全模型由以下几个关键部分构成，各部分在访问控制的不同阶段发挥了各自的作用。
  - 1) 登录过程 (logon process，LP) 。接受本地用户或者远程用户的登录请求，处理用户信息，为用户做一些初始化工作。

  - winlogon.exe

LISS
空天信息安全与可信计算
教育部重点实验室

Windows的安全模型

– 2) 本地安全授权机构 (local security authority，LSA) 。

LSA管理本地安全策略、管理审计策略和设置、为用户生成包含SID和组权限关系的令牌。

LSA验证的过程：LSA通过访问本地SAM（Security Accounts Manager）数据库，可以完成本地用户的验证。

– Local Security Authority Subsystem Service （lsass.exe）

LISS
空天信息安全与可信计算
教育部重点实验室

Windows的安全模型

- 3) 安全账号管理器 (security account manager，SAM) 。维护账号的安全性管理数据库 。
- SAM数据库，又称目录数据库)。

- 存储位置c:/windows/system32/config/sam
- 注册表HKLM\SAM\SAM

LISS
空天信息安全与可信计算
教育部重点实验室

Windows的安全模型

- 4) 安全引用监视器 (security reference monitor，SRM) 。检查存取合法性，防止非法存取和修改。
- SRM是windows内核（ntosknrl.exe)的一个组件。

LISS
空天信息安全与可信计算
教育部重点实验室

Windows的安全概念

1) **安全标识 (security identifier，SID)** 。安全标识和账号唯一对应，在账号创建时创建，账号删除时删除，而且永不再用。

– 安全标识与对应的用户和组的账号信息一起存储在SAM数据库里。

查看 sid

- wmic useraccount get name,sid

LISS
空天信息安全与可信计算
教育部重点实验室

Windows的安全概念

```
C:\WINDOWS\system32\cmd.exe
Microsoft Windows [版本 10.0.14393]
(c) 2016 Microsoft Corporation。保留所有权利。

C:\Users\Administrator>wmic useraccount get name,sid
Name            SID
Administrator   S-1-5-21-836408432-417837563-231288499-500
DefaultAccount  S-1-5-21-836408432-417837563-231288499-503
Guest           S-1-5-21-836408432-417837563-231288499-501


C:\Users\Administrator>
C:\Users\Administrator>_
```

- 第一项S，标示该字符串是SID；
- 第二项，SID的版本号，这里版本号是1；
- 第三项，标志符的颁发机构，Win2000之后的颁发机构都是5；
- 第四项，一系列子资颁发机构
- 第五项-第七项，域
- 第八项，域内的帐户和组。

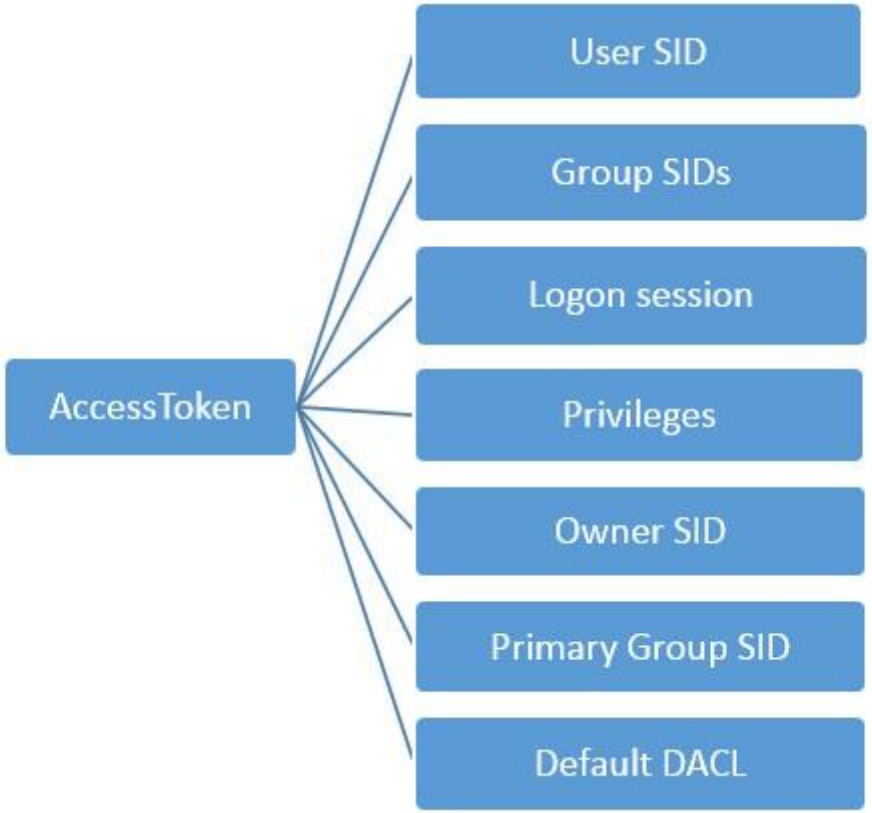
Windows的安全概念

- 2) **访问令牌 (access token)** 。当用户登录时，本地安全授权机构为用户创建一个访问令牌，包括用户名、所在组、安全标识等信息。以后，用户的所有程序都将拥有访问令牌的拷贝。

- Windbg>kd>dt _token可以查看

LISS
空天信息安全与可信计算
教育部重点实验室

Windows的安全概念



Windows的安全概念

- 3) 主体。用户登录到系统之后，本地安全授权机构为用户构造一个访问令牌，这个令牌与该用户所有的操作相联系，用户进行的操作和访问令牌一起构成一个主体。

Windows的安全概念

- 4) **对象、资源、共享资源**。对象的实质是封装了数据和处理过程的一系列信息集合体；资源是用于网络环境的对象；共享资源是在网络上共享的对象。

Windows的安全概念

5) 安全描述符 (security descriptor) 。

- Windows系统为共享资源创建的安全描述符包含了该对象的一组安全属性，分为4个部分：

✓ 拥有者SID

✓ 对象所在组SID

✓ 自主访问控制表 (DAC)，该对象的访问控制表，由对象的所有者控制；

✓ 系统访问控制表 (ACL)，定义操作系统将产生何种类型的审计信息，由系统的安全管理员控制。

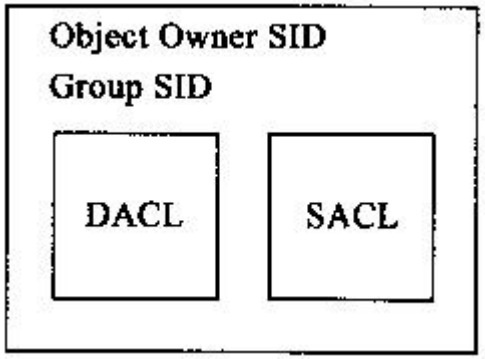
Windows的安全概念

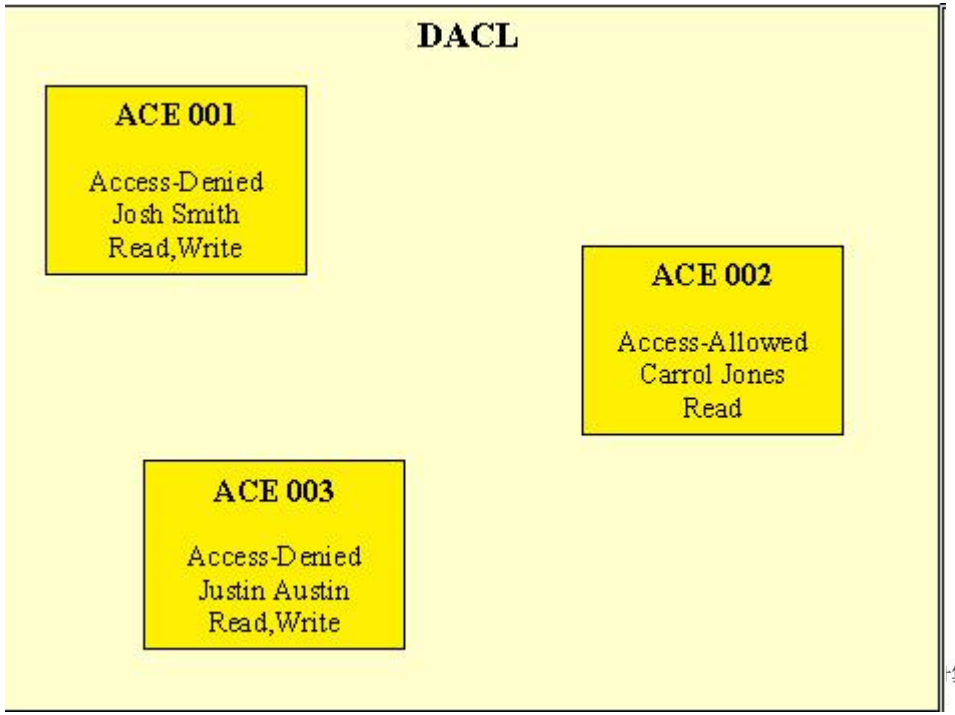
- 其中，安全描述符中的每一个访问控制表(ACL) 都由访问控制项 (ACEs) 组成，用来描述用户或者组对对象的访问或审计权限。
- ACEs权限包含：读、修改、执行、完全控制等。
- ACEs授权类型：Access Allowed、Access Denied和System Audit。前两种用于自主访问控制；后一种用于记录安全日志。

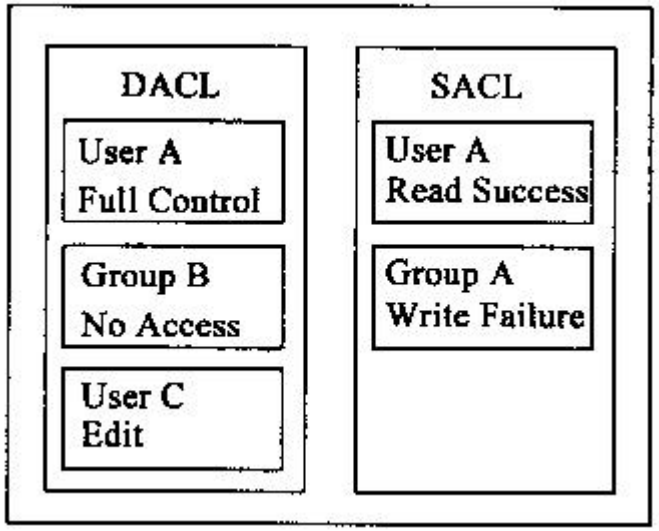
Windows的安全概念

标记
所有者
系统访问控制表(SACL)
自由访问控制表(DACL)

(b)安全描述符







Windows的访问控制过程

Windows的访问控制过程:

Step1(身份认证）:

当一个账号被创建时，Windows为它分配一个SID，并与其他账号信息一起存入SAM数据库。

LISS
空天信息安全与可信计算
教育部重点实验室

Windows的访问控制过程

Step2 (身份认证）：

每次用户登录时，登录主机 (通常为工作站) 的系统首先把用户输入的用户名、口令和用户希望登录的服务器域信息送给安全账号管理器，安全账号管理器将这些信息与SAM数据库中的信息进行比较。

Windows的访问控制过程

Step3 (身份认证完成并授权）：

比较结果，如果匹配，服务器发给工作站允许访问的信息，并返回用户的安全标识和用户所在组的安全标识，工作站系统为用户生成一个进程。

服务器还要记录用户账号的特权、主目录位置、工作站参数等信息。

Windows的访问控制过程

Step4 (授权）：

– 本地安全授权机构为用户创建访问令牌，访问令牌中有当前用户的唯一标识SID，组唯一标识SID以及一些权限标志(Privilege)。此后，用户每新建一个进程，都将访问令牌复制作为该进程的访问令牌。

LISS
空天信息安全与可信计算
教育部重点实验室

Windows的访问控制过程

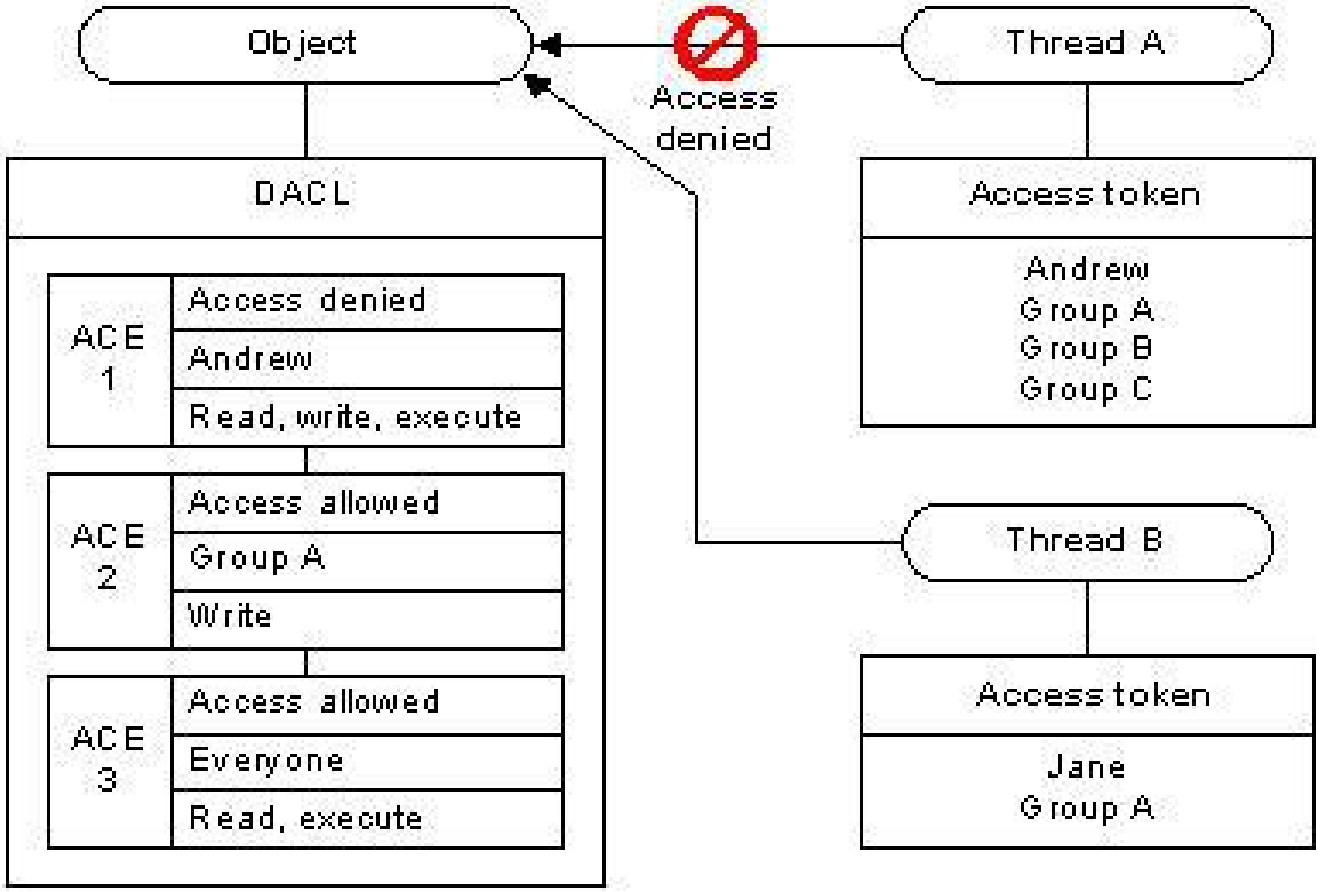
Step5(访问控制）：

–当用户或者用户生成的进程要访问某个对象时，安全引用监视器将用户/进程的访问令牌中的SID与对象安全描述符中的自主访问控制表进行比较，从而决定用户是否有权访问对象。

–在这个过程中应该注意SID对应账号的整个有效期，而访问令牌只对应某一次账号登录(系统出问题后重启)。

LISS
空天信息安全与可信计算
教育部重点实验室

Windows的访问控制过程



作业

1、找到windows系统的sam文件，利用LC5进行破解（选做）

2、查看windows系统的SID、token的组成

3、结合实际系统理解windows访问控制机制

2、Linux基本访问控制机制

- **LINUX基本访问控制机制**
  - 自主访问控制
  - 用户组体现了一点角色的概念

Linux基本访问控制机制

- **LINUX基本访问控制机制**
  - 用户和组
    - /etc/passwd　　/etc/gpasswd
    - /etc/shadow　　/etc/gshadow
  - 文件权限
    - 属主、属组、其他人
    - 读、写、执行
    - 两种表示形式：
      - 数字　0-7
      - 字母　rwx

Linux基本访问控制机制

- Umask 掩码
  - ➢设置用户创建目录和文件时的默认权限
  - – 例：umask 022
    - 则目录权限是755，文件权限是644

Linux基本访问控制机制

- SUID/SGID
  - 一个可执行文件在执行时，linux的内核是根据该进程的运行用户的（有效）ID，包括user id和group id，来决定进程对资源的访问权限。
  - SUID/SGID可以使文件在执行时具有文件所有者或属组的权限
  - 也可通过函数调用 Setuid()、setgid()来设置S位。
  - SUID/SGID往往是入侵的基础

Linux基本访问控制机制

- SUID/SGID

(1)字符设定法

例： chmod u+s test

chomd g+s test

(2)数字设定法

例： chmod 6755 test

find –perm +6000 –type f exec ls –ld {} \; >setuid.txt&

LISS
空天信息安全与可信计算
教育部重点实验室

Linux基本访问控制机制

- SUID实例

  -/usr/bin/passwd 程序，通过S位实现非ROOT用户修改密码的功能。

  -提权到Root

LISS
空天信息安全与可信计算
教育部重点实验室

Linux基本访问控制机制

- 提权到root shell

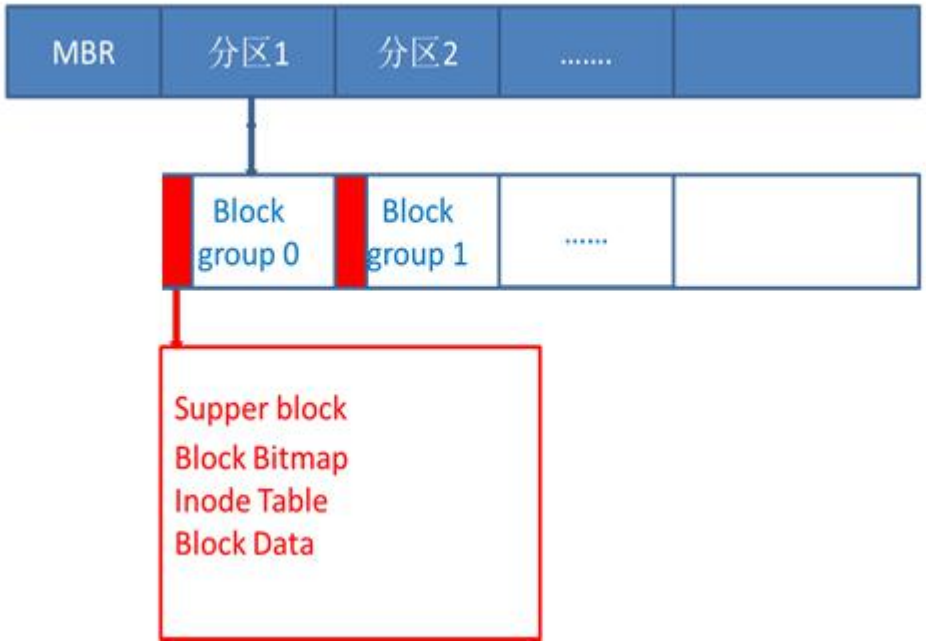
```
#include <stdio.h>
#include <stdlib.h>
int main(){
 char *name[2];
name[0]="/bin/sh";
name[1]=0x0;
setuid(0);
execve(name[0], name, 0x0);
 exit(0); }
```

注意：
1、以非root身份建立shell.c文件，修改shell，使其可执行
2、修改shell，使其属主为root
3、添加S位
此时当非root用户执行shell时刻获得root shell,拥有root权限

LISS
空天信息安全与可信计算
教育部重点实验室

Linux基本访问控制机制实现

- Linux的文件系统



LISS
空天信息安全与可信计算
教育部重点实验室

Linux基本访问控制机制实现

- Inode数据结构

```
struct inode {
    struct list_head    i_sb_list; //链入超级块中的链表
    unsigned long       i_ino; //节点号
    atomic_t            i_count; //引用计数
    unsigned int        i_nlink;  //硬链接数目
    uid_t               i_uid;  //表示文件所有者
    gid_t               i_gid;  //表示文件所有者所属组
    blkcnt_t            i_blocks;
    umode_t             i_mode;  //inode权限

    ................
    ................
```

LISS
空天信息安全与可信计算
教育部重点实验室

Task_struct

- 每个进程都由Task_struct数据结构来定义，task_struct就是我们通常所说的PCB（Process Control Block，简称PCB）。它包含了进程的所有信息。
- 当我们调用fork()时，系统会为我们产生一个task_struct结构。
- 在task_struct中包括以下信息：
- struct task_struct {

  uid_t uid,euid,suid,fsuid;
  gid_t gid,egid,sgid,fsgid;
  int ngroups; //记录进程在多少个用户组中
  gid_t groups[NGROUPS]; //记录进程所在的组

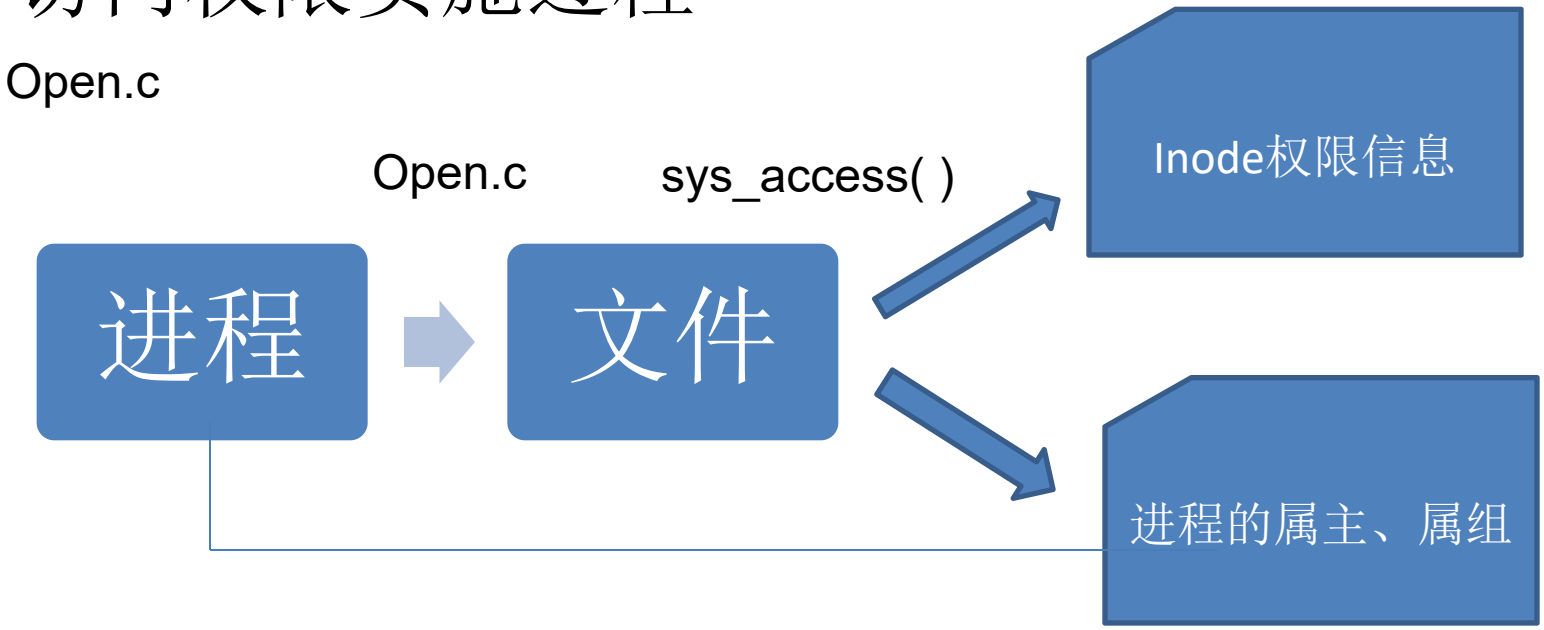
  ……

  ……

LiSS
空天信息安全与可信计算
教育部重点实验室

Linux基本访问控制机制实现

- 访问权限实施过程



3、Selinux

Selinux

内容：

- Selinux的历史
- Selinux安全策略的分类
- Selinux的开启，关闭
- Selinux配置文件简介
- Selinux常用命令
- 安全策略常见名字与概念
- 编写简单策略

SELinux的历史

SELinux是Security-Enhanced Linux的简称，SELinux是一种基于 域–类型 模型（domain-type）的强制访问控制（MAC）安全系统，它由NSA(The National Security Agency)编写并设计成内核模块包含到内核中，相应的某些安全相关的应用也被打了SELinux的补丁，最后还有一个相应的安全策略。

传统Linux的不足

1）**存在特权用户root**

任何人只要得到root的权限，对于整个系统都可以为所欲为。这一点Windows也一样。

2）**对于文件的访问权划分不够细**

在linux系统里，对于文件的操作，只有「所有者」，「所有组」，「其他」这 3 类的划分。

3）**SUID程序的权限升级**

如果设置了SUID权限的程序有了漏洞的话，很容易被攻击者所利用

4）**D A C (Discretionary Access Control)问题**

文件的所有者可以对文件进行所有的操作

LISS
空天信息安全与可信计算
教育部重点实验室

Selinux的优点

1）更严格和细粒度的访问控制

对于所有的文件、目录、端口这类的资源的访问，都可以是基于策略设定的，这些策略是由管理员定制的、一般用户是没有权限更改的。

2）对于进程只赋予最小的权限

3）防止权限升级

4）对于用户只赋予与最小的权限

对于用户来说，被划分成一些ROLE，例如，即使是ROOT用户，你要是不在sysadm_r里，也还是不能实行sysadm_t管理操作的。

SELinux 常见概念

- MAC/TE
- TE的安全上下文
- 策略
- 域转换

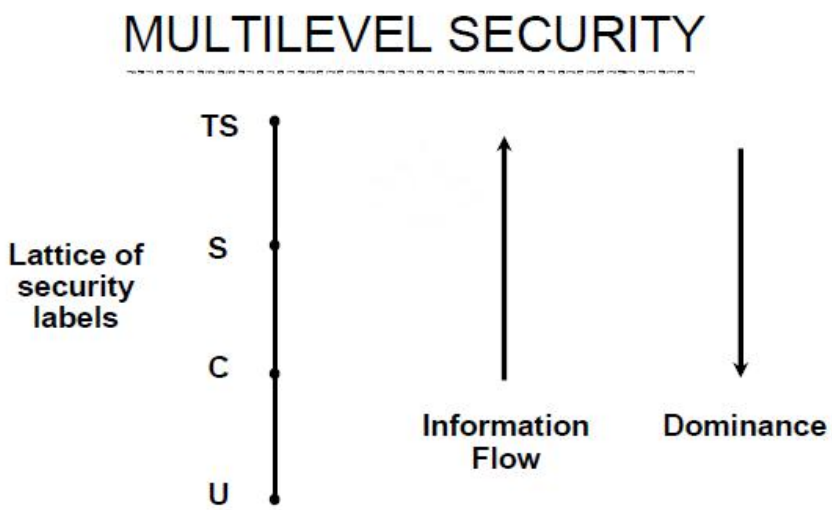
Selinux安全策略的分类

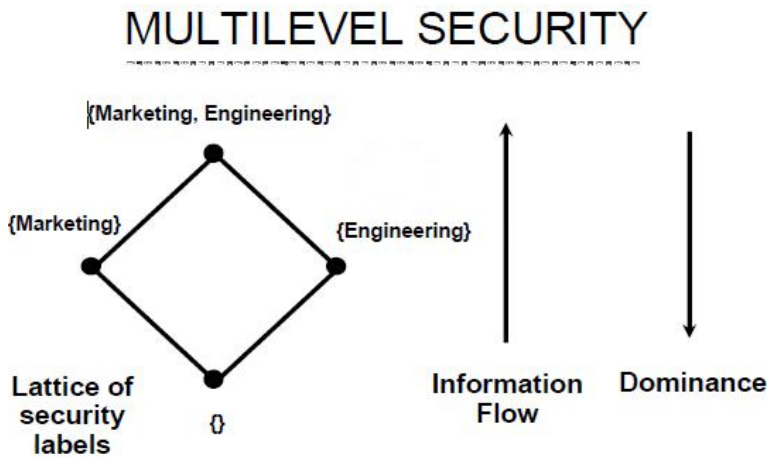
- **MAC**
- **TE**

MAC(Mandatory access control)

- 用于将系统中的信息分密级和类进行管理，以保证每个用户只能访问到那些被标明可以由他访问的信息的一种访问约束机制。
- 通俗的来说，在强制访问控制下，用户（或其他主体）与文件（或其他客体）都被标记了固定的安全属性（如安全级、访问权限等），在每次访问发生时，系统检测安全属性以便确定一个用户是否有权访问该文件。
- 其中多级安全（MultiLevel Secure, MLS）就是一种强制访问控制策略。

BLP(Bell-La Padula)

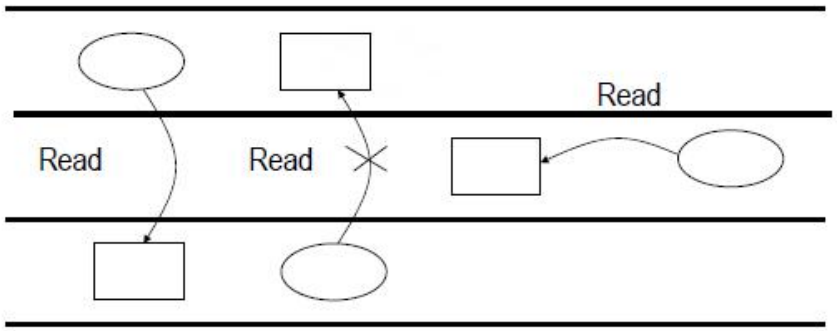




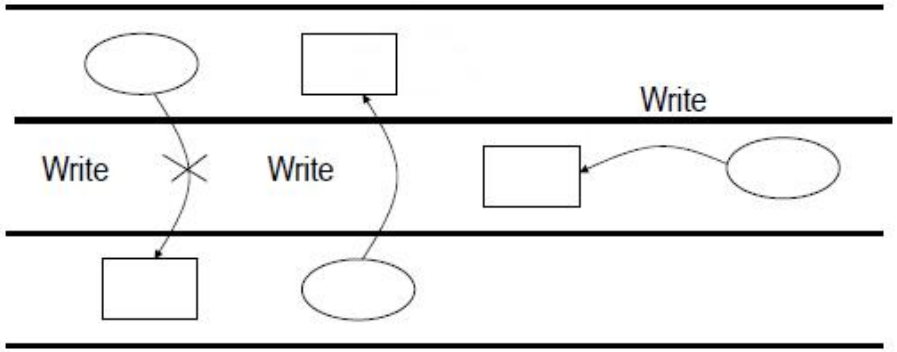
LiSS
空天信息安全与可信计算
教育部重点实验室

BLP(Bell-La Padula)

SIMPLE PROPERTY



STAR PROPERTY



LISS
空天信息安全与可信计算
教育部重点实验室

TE(Type Enforcement)

对所有的文件都赋予一个叫type的文件类型标签，对于所有的进程也赋予各自的一个叫 domain的标签。Domain标签能够执行的操作也是在访问控制策略里定义好的。

例如： http_t, passwd_t

LISS
空天信息安全与可信计算
教育部重点实验室

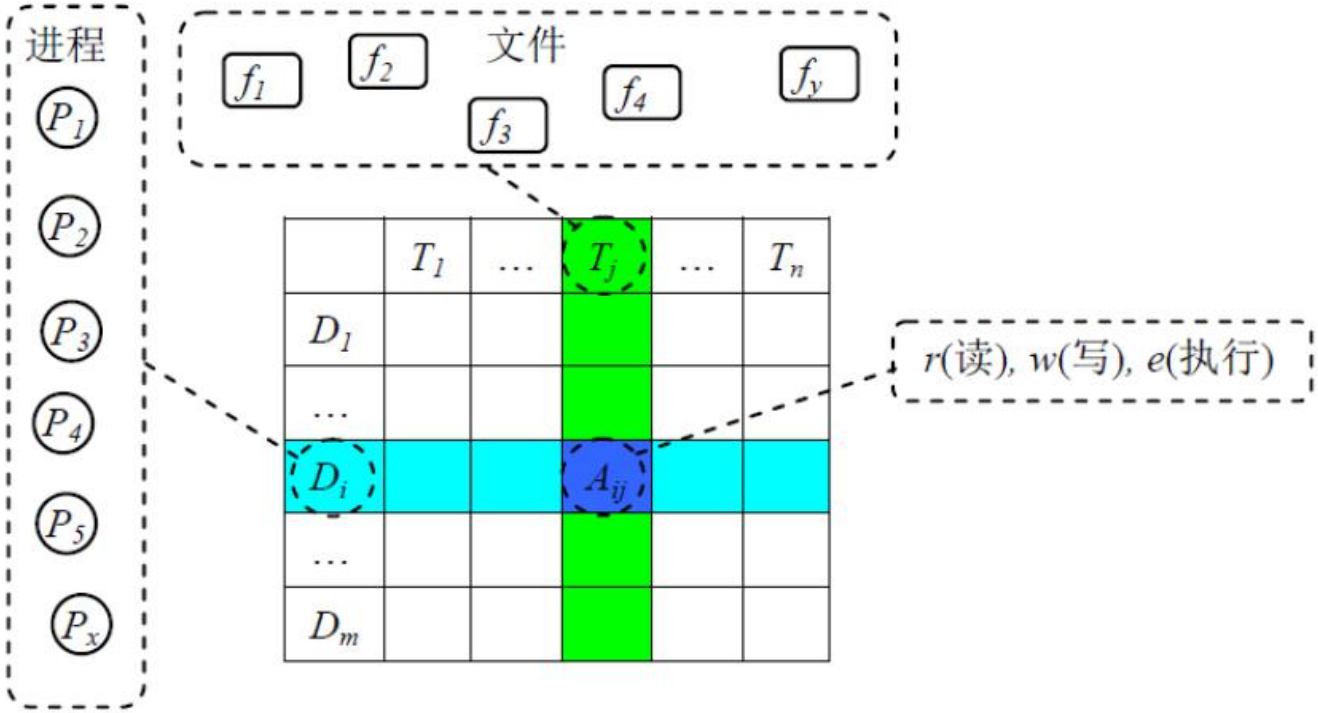
TE(Type Enforcement)

- 由于历史原因，一个进程的类型通常被称为一个域(域)
- “域”和“域类型”都是指同一个，在平时我们看到文档中以及日常交流中，我们认为域、域类型、主体类型和进程类型都是指同一种意思

例如： http_d, passwd_t

LISS
空天信息安全与可信计算
教育部重点实验室

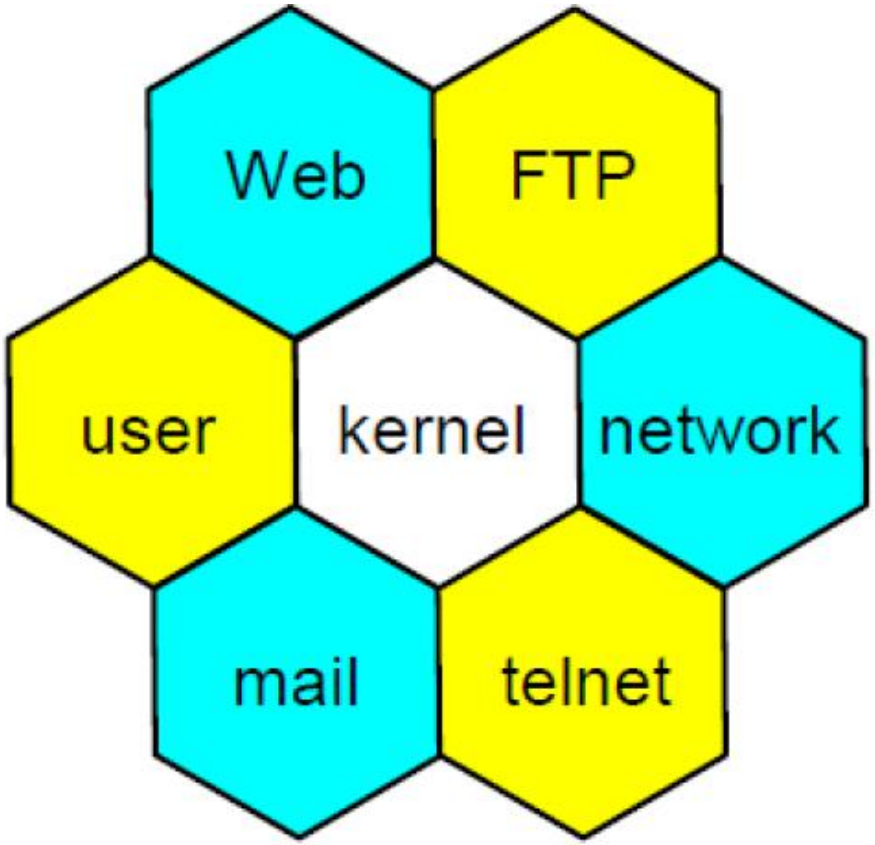
TE(Type Enforcement)



访问控制授权的依据主要是域对类型所拥有的访问权限

LISS
空天信息安全与可信计算
教育部重点实验室

TE(Type Enforcement)



LISS
空天信息安全与可信计算
教育部重点实验室

SeLinux

- 类型的细分
  - 增加客体类别概念
    - 普通文件、目录、进程、套接字、文件系统
- 权限的细化
  - *file*类别：*read*、*write*、*execute*、*getattr*、*create*
  - *dir*类别：*read*、*write*、*search*、*rmdir*
  - *process*类别：*signal*、*transition*、*fork*、*getattr*
  - *socket*类别：*bind*、*listen*、*connect*、*accept*
  - *filesystem*类别：*mount*、*unmount*
- 域 & 类型 → 类型
  - 域：域类型、主体类型

SeLinux的安全上下文

在SELinux当中，所有操作系统访问控制都是以关联的客体和主体的某种访问控制属性为基础。

- 访问控制属性叫做安全上下文
- 所有的客体以及主体都有与其有关联的安全上下文
- 一个安全上下文由三部分组成：用户、角色和类型标识符

LISS
空天信息安全与可信计算
教育部重点实验室

SeLinux的安全上下文

终端

文件(F) 编辑(E) 查看(V) 终端(T) 标签(B) 帮助(H)

```
sysadm_u:sysadm_r:sysadm_t:s0-s15:c0.c255 secadm 18972 17944 40 08:58 ? 00:46:21
 /usr/lib/nspluginwrapper/npviewer.bin --plugin /usr/lib64/mozilla/plugins/libfl
system_u:system_r:kernel_t:s15:c0.c255 secadm 27687 45  0 09:25 ?      00:00:00
[rpciod/0]
system_u:system_r:kernel_t:s15:c0.c255 secadm 27688 45  0 09:25 ?      00:00:00
[rpciod/1]
system_u:system_r:kernel_t:s15:c0.c255 secadm 27718 1  0 09:25 ?       00:00:00
[lockd]
bash-3.2# ps -efZ
LABEL                              UID        PID  PPID  C STIME TTY          TIME CMD
system_u:system_r:init_t:s0-s15:c0.c255 secadm 1    0  0 08:17 ?        00:00:00 init [5]
system_u:system_r:kernel_t:s15:c0.c255 secadm 2    1  0 08:17 ?        00:00:00 [migration/0]
system_u:system_r:kernel_t:s15:c0.c255 secadm 3    1  0 08:17 ?        00:00:00 [ksoftirqd/0]
system_u:system_r:kernel_t:s15:c0.c255 secadm 4    1  0 08:17 ?        00:00:00 [watchdog/0]
system_u:system_r:kernel_t:s15:c0.c255 secadm 5    1  0 08:17 ?        00:00:00 [migration/1]
system_u:system_r:kernel_t:s15:c0.c255 secadm 6    1  0 08:17 ?        00:00:00 [ksoftirqd/1]
system_u:system_r:kernel_t:s15:c0.c255 secadm 7    1  0 08:17 ?        00:00:00 [watchdog/1]
system_u:system_r:kernel_t:s15:c0.c255 secadm 8    1  0 08:17 ?        00:00:00 [events/0]
system_u:system_r:kernel_t:s15:c0.c255 secadm 9    1  0 08:17 ?        00:00:00 [events/1]
system_u:system_r:kernel_t:s15:c0.c255 secadm 10   1  0 08:17 ?        00:00:00 [khelper]
system_u:system_r:kernel_t:s15:c0.c255 secadm 45   1  0 08:17 ?        00:00:00 [kthread]
system_u:system_r:kernel_t:s15:c0.c255 secadm 50  45  0 08:17 ?        00:00:00 [kblockd/0]
system_u:system_r:kernel_t:s15:c0.c255 secadm 51  45  0 08:17 ?        00:00:00 [kblockd/1]
system_u:system_r:kernel_t:s15:c0.c255 secadm 52  45  0 08:17 ?        00:00:00 [kacpid]
```

策略描述语言

因为SELinux默认不允许任何访问，所以，所有的访问都必须明确授权，不管用户／组ID是什么，在SELinux中，通过allow语句对主体授权对客体的访问权限

Allow 规则由四部分组成

源类型(Source type(s)) 通常是尝试访问进程的域类型

目标类型(Target type(s)) 被进程访问的客体的类型

客体类别(Object class(es)) 指定允许访问的客体的类型 如file,dir,socket等

许可(Pemission(s)) 象征目标类型允许源类型访问客体类型的访问种类

策略描述语言

例如:

allow user_t bin_t: file {read execute getattr}

这个例子显示了TE allow 规则的基础语法，这个规则包含两个类型标识符:

源类型(或主体类型或域)user_t

目标类型(或客体类型)bin_t

标识符file是定义在策略的客体类别名称，表示的是一个普通文件，大括号的许可是文件客体类别有效许可

整条规则解释如下:

拥有域类型user_t的进程可以读 / 执行或获取具体有bin_t类型的文件客体的属性

LISS
空天信息安全与可信计算
教育部重点实验室

角色

1、角色的作用

SELinux通过SC中的role实现了“基于角色的访问控制”(RBAC－Role Based Access Control)。在SELinux中，并不直接建立用户和type之间的联系，而是通过角色作为桥梁，优势是：

1) 降低policy复杂度：可能有上百个用户和上千种type，但是所需的不同角色只有若干个；role作为user和type之间的“中间层”，便于限制user的能力；

2) 实现不同用户优先级－当前用户通过扮演某种角色，以获得相应的能力。特权角色只能由特权用户来扮演。

RBAC的两个语法：用户声明语句和角色声明语句，比如：

user joe roles {user_r};

role user_r types {user_t passwd_t);

LISS
空天信息安全与可信计算
教育部重点实验室

安全策略开启，关闭

在安全操作系统上，SELinux其状态有三种:

Enforcing
Permissive
disabled

查看SELinux状态可用sestatus 以及getenforce命令

如何开启，关闭SELinux，也即在三种状态之间切换？
使用secadm用户登录安全操作系统
#setenforce 0 ----将SELinux状态调为permissive
#setenforce 1 ----将SELinux状态调为Enforcing

如要将SELinux策略置为disabled，则需要修改SELinux配置文件，然后重启系统

Ubuntu下selinux的使用方法

- 1.安装
- 2.安装好之后重启selinux就可以用了。
- 3. ls –ldZ 检查

LISS
空天信息安全与可信计算
教育部重点实验室

SELinux配置文件

SELinux配置文件有:
/boot/grug/grub.conf
/etc/selinux/config

root (hd0,0)
kernel /vmlinuz-2.6.18-164.el5 ro root=LABEL=/1 rhgb quiet selinux=1 enforcing=0
initrd /initrd-2.6.18-164.el5.img

其中selinux = 1 表示开机启动SELinux，enforcing = 0 表示SELinux的状态为permissive

SELinux配置文件

```
bash-3.2# more /etc/selinux/config
# This file controls the state of SELinux on the system.
# SELINUX= can take one of these three values:
#       enforcing - SELinux security policy is enforced.
#       permissive - SELinux prints warnings instead of enforcing.
#       disabled - SELinux is fully disabled.
SELINUX=enforcing
# SELINUXTYPE= type of policy in use. Possible values are:
#       targeted - Only targeted network daemons are protected.
#       strict - Full SELinux protection.
SELINUXTYPE=refpolicy
```

系统对两个文件的读取方式:

当grub.conf中有相SELinux相关选项时，则读取grub.conf中的配置信息，而不读取/etc/selinux/config中的信息，否则读取/etc/selinux/config中的信息

SELINUX =enforcing　　表示SELinux状态为enforcing

SELINUXTYPE=refpolicy　表示策略类型为 refpolicy

LISS
空天信息安全与可信计算
教育部重点实验室

SELinux常用命令

getenforce	查看当前系统SELinux状态
setenforce	设置当前系统SELinux状态
seinfo	查看当前系统SELinux信息
sestatus	查看当前系统SELinux详细状态
semoudle	对SELinux模块进行管理
chcon	更改文件、目录、设备的安全上下文
restorecon	恢复文件、目录、设备的安全上下文
sesearch	查看系统详细策略信息

SELinux常用命令

#apt-get install httpd

#ls –ldZ /usr/sbin/httpd /var/www/html

```
[root@livecd ~]# ls -dZ /usr/sbin/httpd  /var/www/html
-rwxr-xr-x. root root system_u:object_r:httpd_exec_t:s0 /usr/sbin/httpd
drwxr-xr-x. root root system_u:object_r:httpd_sys_content_t:s0 /var/www/html
[root@livecd ~]#
```

SELinux常用命令

#cp /etc/hosts /root

#ls –ldZ /etc/hosts /root/hosts /root

```
root@livecd ~]# ls -dZ /usr/sbin/httpd  /var/www/html
rwxr-xr-x. root root system_u:object_r:httpd_exec_t:s0 /usr/sbin/httpd
rwxr-xr-x. root root system_u:object_r:httpd_sys_content_t:s0 /var/www/html
root@livecd ~]# cp /etc/hosts  /root
root@livecd ~]# ls -ldZ /etc/hosts /root/hosts /root
rw-r--r--. root root system_u:object_r:net_conf_t:s0  /etc/hosts
r-xr-x---. root root system_u:object_r:admin_home_t:s0 /root
rw-r--r--. root root unconfined_u:object_r:admin_home_t:s0 /root/hosts
root@livecd ~]#
```

SELinux常用命令

#chcon [-R] [-t type] [-u user] [-r role] 文件
#chron –t net_conf_t /tmp/hosts

```
[root@localhost www]# ls -lZ /etc/hosts  /root/hosts
-rw-r--r--. root root system_u:object_r:net_conf_t:s0  /etc/hosts
-rw-r--r--. root root unconfined_u:object_r:admin_home_t:s0 /root/hosts
[root@localhost www]# chcon -t net_conf_t /root/hosts
[root@localhost www]# ls -lZ /root/hosts
-rw-r--r--. root root unconfined_u:object_r:net_conf_t:s0 /root/hosts
[root@localhost www]#
```

SELinux常用命令

#semanage {login|user|port|interface|fcontext|translation} –l
#semanage fcontext -{a|d|m} –t type files

#semanage fcontext -l
#semanage fcontext -a –t public_content_t "/root/test"

#yum install policycoreutils-python

LISS
空天信息安全与可信计算
教育部重点实验室

SELinux常用命令

#seinfo
#yum install setools-console

#seinfo –b |grep httpd

SELinux常用命令

#sesearch
#sesearch –all –t httpd_sys_content_t

#getsebool –a
#setsebool –P httpd_enable_homedirs=1

SELinux日志

cat /var/log/messages

Selinux实现架构

- LSM（Linux security module)- LSM框架的思想是允许安全模块以插件形式进入内核，以便更严格地控制Linux默认的基于身份的自主访问控制（DAC）安全性。LSM在内核系统调用逻辑中提供了一套钩子（hooks），这些钩子通常放在标准Linux访问检查后、且内核调用访问真实资源之前.

LiSS
空天信息安全与可信计算
教育部重点实验室

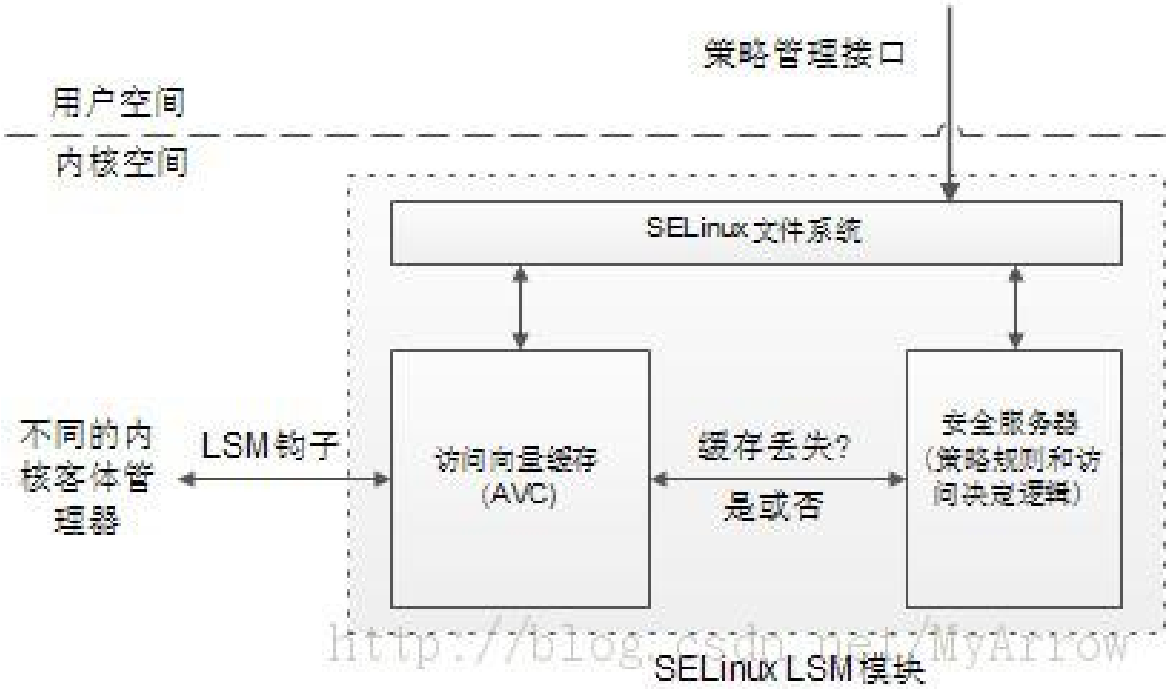
Selinux实现架构

LSM的优势

- 在关键的特定内核数据结构中加入了安全域；
- 在内核源码中不同的关键点处插入对安全钩子函数的调用；
- 提供了一个通用的安全系统调用；
- 提供了注册和注销函数，使得访问控制策略可以以内核模块方式实现；

Selinux实现架构

- SELinux LSM模块架构



http://blog.csdn.net/MyArrow

LSM Hook函数

- Hook 函数（钩子函数）
  - 钩子函数也叫回调函数，是通过函数指针来实现的。

Hook函数

- int *p;
- int a， b；
- 我们可以让指针p先后指向a, b，这样，p就先后代表了不同变量的地址
- p = &a;
- p = &b;
- 同样地，函数的指针可以指向不同的函数，从而完成不同的功能。
- 例如，定义函数指针：
- int (* g_pFun) (int x, int y);

LISS
空天信息安全与可信计算
教育部重点实验室

Hook函数

有两个函数：

/*返回两个参数中的最大值*/

- int Max(int x, int y)

  { }
- /*返回两个参数中的最小值*/
- int Min(int x, int y)

  { }

LISS
空天信息安全与可信计算
教育部重点实验室

Hook函数

```
int main(int argc, char* argv[])
    {  int r;
       int a = 10;
       int b = 15;
       g_pFun = Max;
      r= g_pFun(a, b); /*相当于执行函数Max*/
       printf("%d\n", r);
       g_pFun = Min;
       r= g_pFun(a, b); /*相当于执行函数Min*/
       printf("%d\n", r);
       return 0;
      }
```

LISS
空天信息安全与可信计算
教育部重点实验室

Hook函数

- Max，Min函数就是钩子函数了，把函数指针g_pFun指向函数Max，Min的过程，就是“挂钩子”的过程，把钩子函数“挂”到函数指针上，很形象。

Hook函数

- 注册：常常把挂钩子的过程叫做注册，会提供一个注册函数，让使用者把自己编写的钩子函数挂在已经声明的函数指针上，这个注册函数的参数就是我们的函数指针
- int RegFun(int (* pFun)(int x, int y)) /*注册函数的参数是函数指针*/

```
{ g_pFun = pFun;
  return 0;   }
```

- 调用RegFun(Max)和RegFun(Min),就可以把钩子函数挂上去了。

LISS
空天信息安全与可信计算
教育部重点实验室

完整的钩子函数实例

- 主函数：
- int (* g_pFun) (int x, int y); /*函数指针*/

```
int Plat()
{
    int r;
    int a = 10;
    int b = 15;
    r= g_pFun(a, b); /*这里要做一个操作，但是具体的操作还不确定*/
    printf("%d\n", r);
    return 0;
}
```

LISS
空天信息安全与可信计算
教育部重点实验室

完整的钩子函数实例

完成具体功能的钩子函数：

- int Max(int x, int y)

```
{
    if(x>y)
        return x;
    else
        return y;
}
```

- int Min(int x, int y)

```
{
    if(x<y)
        return x;
    else
        return y;
}
```

LISS
空天信息安全与可信计算
教育部重点实验室

完整的钩子函数实例

- 注册函数：
- int RegFun(int (* pFun)(int x, int y))

```
{
    g_pFun = pFun;
    return 0;
}
```

LISS
空天信息安全与可信计算
教育部重点实验室

完整的钩子函数实例

- **注册钩子函数：**
- 如果应用模块注册：

  RegFun(Max);

  则运行 main 函数时，输出：15
- 如果应用模块注册：

  RegFun(Min)

  运行 main 函数时，输出：10

这样，平台部分无需修改任何代码，只是应用模块注册了不同的钩子函数，就能够完成不同的功能，这就是钩子函数的妙用。

LSM Hook函数

- LSM Hook函数包括：
  - Task hook
  - Program loading hook
  - IPC hook
  - File system hook
  - Network hook

Task Hooks

- struct task_security_struct {
  - struct task_struct *task; /* 指向原task对象 */
  - u32 osid; /* 最后一次execve前的SID*/
  - u32 sid; /* 当前进程的SID */
  - u32 exec_sid; /* exec SID */
  - u32 create_sid; /* fscreate SID */
  - u32 keycreate_sid; /* keycreate SID */
  - u32 sockcreate_sid; /* 套接字 SID */
  - u32 ptrace_sid; /* SID of ptrace */
  - };
- int (*task_create) (unsigned long clone_flags);
  - 该函数在调用fork时调用。它调用static int task_has_perm(struct task_struct *tsk1,struct task_struct *tsk2,u32 perms)主体和客体都是当前进程，perms是所要申请检查的权限。
- int (*task_alloc_security) (struct task_struct * p);
- void (*task_free_security) (struct task_struct * p);

Selinux策略表示

- AV
  - 访问向量（Access vectors，Avs），用来表示策略的规则。如允许域访问各种系统客体，一个AV是一套许可。一个基本的AV规则是主体和客体的类型对，AV规则的语法如下：
- <av_kind> <source_type(s)> <target_type(s)>:<class(es)> <permission(s)>

LISS
空天信息安全与可信计算
教育部重点实验室

Selinux策略

```
28
29  # 使用权能.
30  allow ping_t self:capability { net_raw setuid };
31
32  # 访问终端.
33  allow ping_t admin_tty_type:chr_file rw_file_perms;
34  allow ping_t privfd:fd use;
35  dontaudit ping_t fs_t:filesystem getattr;
36
37  # 尝试访问/var/run
38  dontaudit ping_t var_t:dir search;
39  ifdef(`hide_broken_symptoms', `
40   dontaudit ping_t init_t:fd use;
41  ')
```

AV

<av_kind>在以下四种设置：

- allow　表示允许主体对客体执行允许的操作。
- neverallow　表示不允许主体对客体执行指定的操作。
- auditallow　表示允许操作并记录访问决策信息。
- dontaudit　表示不记录违反规则的决策信息，且违反规则不影响运行。

AV

- **AV的例子：**
  - allow init_t apache_exec_t : file execute;
  - allow userdomain shell_exec_t: file{ read getattr lock execute ioctl};

实验 一

1、在/home下创建一个文件夹test

2、在文件夹下创建一个文本文件

3、利用两种方法将文本文件的权限设置为属主完全控制、组可读和执行、其它用户只读

4、将系统新建文件和文件夹的权限设置为644和755，重新创建文件观察权限值

5、建立一个可执行文件，设置其Suid位；执行该文件，并通过命令观察该文件权限的变化。

6、执行课件suid部分提权到root shell的例子，分析其原理

LISS
空天信息安全与可信计算
教育部重点实验室

实验二

1、启动Selinux模块

2、查看系统的安全上下文

3、安装httpd

4、修改 /var/www文件夹的类型，使其为httpd不允许访问的类型，然后检查web服务器是否还可以正常使用。

LISS
空天信息安全与可信计算
教育部重点实验室

谢　　谢！

LISS
空天信息安全与可信计算
教育部重点实验室